SECCIÓN 4.7

Movimiento lateral y actividad interna sospechosa

Temas de esta sección:

- Qué es movimiento lateral y por qué es importante detectarlo temprano
- Movimiento lateral no siempre parece malware
- Protocolos: SMB, RDP, WinRM, WMI, LDAP, Kerberos, SSH
- Reconocimiento interno antes del movimiento lateral
- Shares administrativos, creación remota de servicios
- Uso de credenciales válidas y cuentas privilegiadas
- IT legítima vs movimiento lateral: cómo diferenciar

El movimiento lateral ocurre cuando una amenaza intenta desplazarse desde un sistema comprometido hacia otros dentro de la organización. Puede verse como actividad completamente legítima porque los atacantes usan protocolos y herramientas normales del entorno.

Puede verse como:	La diferencia está en:
Login remoto exitoso	**¿Quién lo hizo?**
Conexión SMB a carpetas compartidas	**¿Desde dónde?**
RDP hacia servidor	**¿Hacia dónde?**
WinRM / ejecución remota	**¿Con qué cuenta?**
Uso de cuenta administrativa	**¿En qué horario?**
Copia de archivo a ADMIN$	**¿Había autorización?**

4.7 | Protocolos usados en movimiento lateral

Cada protocolo puede ser legítimo o indicar movimiento lateral según el contexto:

Protocolo / Puerto	Uso normal	Señal en movimiento lateral
`SMB (445)`	Compartir archivos, impresoras y recursos en red	*Acceso a ADMIN$, C$, IPC$ · Copia de ejecutables · Autenticaciones fallidas masivas*
`RDP (3389)`	Acceso remoto de escritorio gráfico	*Login RDP desde host de usuario no administrativo · Fuera de horario · Sin ticket*
`WinRM (5985/5986)`	Administración remota de Windows via PowerShell	*Invoke-Command remoto · Enter-PSSession desde host no administrativo*
`WMI`	Gestión y administración remota de sistemas Windows	*wmic /node: process call create · Ejecución remota de comandos*
`Kerberos / LDAP`	Autenticación de dominio y consultas a Active Directory	*Pass-the-Ticket · Kerberoasting · ldap queries de reconocimiento*
`SSH (22)`	Acceso remoto seguro en Linux/Unix	*SSH desde proceso web (apache→bash→ssh) · Lateral en entornos Linux*

4.7 | Reconocimiento interno antes del movimiento lateral

Antes de moverse lateralmente, el atacante necesita entender el entorno. Reconocimiento interno típico:

```
# Comandos de reconocimiento frecuentes
whoami /all           # Privilegios del usuario actual
ipconfig /all         # Configuración de red
arp -a                # Hosts visibles en red local
net view /domain      # Equipos en el dominio
nltest /dclist:dom    # Controladores de dominio
net group 'Domain Admins' /domain  # Cuentas privilegiadas
net localgroup administrators      # Admins locales
nslookup / ping       # Resolución y conectividad
tasklist / ps aux     # Procesos en ejecución
netstat -ano          # Conexiones activas
```

¿Por qué importa en SOC?

▸ Estos comandos en secuencia en pocos minutos desde un host de usuario son una señal fuerte de reconocimiento post-compromiso.

▸ Solos pueden ser legítimos (un admin revisando su equipo). Combinados, en poco tiempo, desde host no técnico, son reconocimiento.

▸ Señal fuerte: mismo host ejecuta whoami, net view, nltest y net group en menos de 3 minutos sin ticket activo.

El reconocimiento previo al movimiento lateral suele ser visible en EDR como una ráfaga de comandos de enumeración del sistema. Correlacionar con alertas previas de ejecución.

4.7 | IT legítima vs movimiento lateral: cómo diferenciar

El desafío central: actividad de IT puede parecer sospechosa, y movimiento lateral puede parecer IT. La diferencia está en el contexto:

Tipo	Usuario	Host origen	Proceso	Destinos	Ticket	Horario
Actividad legítima de IT	soporte.admin	IT-ADM-02	software_deploy.exe	120 endpoints	CHG-2026-2201	22:00 (ventana)
Movimiento lateral sospechoso	rrhh.silva	HR-LAP-044	psexec.exe	18 servidores	Ninguno	01:30 AM

Señales que aumentan la prioridad:

- Usuario no técnico
- Cuenta privilegiada
- Host origen no administrativo
- Varios destinos internos
- SMB/RDP/WinRM fuera de patrón
- Copia a ADMIN$
- Creación remota de servicio
- Sin ticket
- Actividad post-phishing
- Horario inusual
- Acceso a servidores críticos

4.7 | Escenario crítico: cuenta privilegiada en movimiento lateral

Uno de los escenarios más críticos que puede ver un analista SOC:

```
Alert: Privileged account lateral activity

User: admin.backup
Source Host: USER-LAP-091 (notebook de usuario)
Destinations:
- APP-SRV-01  -  FILE-SRV-02  -  DC-01
Protocols: SMB + WinRM
Actions:
- File copied to ADMIN$
- Remote service created: WindowsUpdateCheck
- Binary: C:\Windows\Temp\update.exe
Time: 02:30 AM  |  Ticket: None
```

Por qué es crítico:

- ⚠ Cuenta privilegiada (admin.backup)
- ⚠ Origen: notebook de usuario (no admin)
- ⚠ Accede a DC-01 (controlador de dominio)
- ⚠ Copia a ADMIN$ y crea servicio remoto
- ⚠ Binario en ruta temporal
- ⚠ Sin ticket, horario inusual
- ⚠ Si llega al DC: compromiso total del dominio

ESCALAMIENTO INMEDIATO. Posible movimiento lateral con acceso a activo crítico (DC).
El acceso al controlador de dominio puede comprometer toda la organización.